

Security at AI Speed — A Note to Internal Audit

1. Why This Matters to You

The boards and audit committees you report to now read about AI-speed attacks in the news every week. They no longer want confirmation that controls exist on paper. They want confidence that the organization can still see, decide, and act when an attack moves faster than a meeting can be called. That is a different question — and the audit profession has not yet adjusted to it. If your reports continue to describe the existence of process while the operating model quietly drifts past its ability to execute, the assurance you provide is preserving its form and losing its function. Internal Audit either becomes the discipline that proves the organisation can move at the required speed, or it becomes a function the board stops relying on for the questions that now matter most.

2. The Core Problem

The attacker no longer waits while we coordinate. Reconnaissance, access, movement, and impact now happen as one continuous flow, often in minutes. The traditional response sequence — detect, escalate, validate, discuss, approve, act — is structurally too slow against this. Periodic governance, retrospective reporting, and annual control testing assume time that no longer exists. The result is a widening gap between what audit reports say is true about the control environment and what is actually executable when the clock is running. Authority that has not been pre-committed before an event becomes authority surrendered the moment pressure arrives. Control coverage tells you nothing about whether the few controls that matter will fire in time.

3. What You Must Own

- **Test executability, not existence.** The mandate has shifted: assess whether the chosen operating model still works at speed — not whether a control is documented. A control that depends on slow interpretation during an event is not a control; it is an administrative artefact.
- **Treat post-event evidence as insufficient.** Control reality recreated after an incident no longer meets the standard of assurance. Continuous, live evidence is the new baseline. Anything reconstructed from memory and timestamps is a description, not proof.
- **Prove that pre-authorizations are real.** For every containment action leadership claims to have approved in advance — disabling an identity, revoking a session, isolating a device, degrading a service — verify it can actually execute, by the named owner, within the named window, under realistic conditions. Anything else is policy theatre.
- **Make unresolved risk explainable.** For every risky condition that remains open, be able to answer three questions on demand: why does it remain unresolved, who explicitly accepted it, and what happens to the business if it is exploited tomorrow.
- **Hold the line on measurability.** Speed, executability, and control reality must be evidenced as measurable properties. Narrative claims, maturity scores, and self-assessed effectiveness ratings no longer carry the weight the board now needs.
- **Surface the gap between authority on paper and authority in practice.** Where decision rights for disruptive action are unclear, contested, or quietly unresolved, that is itself a finding — not a footnote.

4. What Must Change Now

- **From periodic testing to continuous evidence.** Move away from annual and quarterly sampling. Draw assurance from the same live telemetry that security and operations already use. One operational truth, audited from the same picture — not a parallel version constructed for the audit report.
- **From control coverage to control reality.** Stop reporting on how many controls exist. Report on whether the controls that matter most actually change attacker momentum before it becomes business consequence, on the named critical services.
- **From review to rehearsed execution.** Audit pre-authorized actions the way a financial close is audited: with observed, time-stamped evidence that the action ran correctly under conditions that resemble a real event — not a friendly drill scheduled at a convenient time.
- **From siloed findings to one shared risk map.** Align with security, operations, and risk on a single live picture of exposure, identity, and consequence. If Internal Audit works from a different version of reality than the people responding to the incident, the audit version will always lose.
- **From "controls were in place" to "decisions were owned".** Trace every accepted risk to a named accountable owner in the business, with a recorded decision, a stated tolerance for loss, and a defined review trigger. Quiet acceptance is no longer acceptance.

5. The One Question to Bring to the Boardroom

If a determined attacker moved against our most critical service tomorrow morning, can we prove — with evidence available now, not reconstructed afterwards — that every containment action we have authorized on paper would actually execute, by a named owner, inside the window we have committed to?